

STP Claim Root Attack — Documentación Técnica

Autor: Junior Javier Santos Perez

Matrícula: 2024-1599

Herramienta: stp_root_claim.py

Plataforma de laboratorio: GNS3 + Kali Linux 2025.3

Link video: <https://www.youtube.com/watch?v=Mv7JZszYmu4&t=2s>

Enlace GitHub: <https://github.com/juniorjaviersantosperez/STP-Claim-Root-Attack>

Tabla de Contenidos

1. [Objetivo del Laboratorio](#)
2. [Objetivo del Script](#)
3. [Parámetros Utilizados](#)
4. [Requisitos para el Uso de la Herramienta](#)
5. [Descripción del Funcionamiento del Script](#)
6. [Documentación de la Red](#)
7. [Topología](#)
8. [Capturas de Pantalla](#)
9. [Medidas de Mitigación / Contramedidas](#)

Objetivo del Laboratorio

Demostrar de forma práctica y controlada la ejecución de un ataque de **STP Root Bridge Hijack (Claim Root Attack)** sobre una topología de switches Cisco simulada en GNS3, con el fin de:

- Comprender cómo el protocolo STP (Spanning Tree Protocol) puede ser manipulado mediante BPDUs maliciosos.
- Observar cómo un atacante puede proclamarse Root Bridge legítimo enviando BPDUs con prioridad 0.
- Verificar el cambio de Root Bridge en los switches de la topología mediante `show spanning-tree vlan 1`.
- Analizar el tráfico BPDU capturado con `tcpdump` como evidencia del ataque.
- Proponer e implementar contramedidas efectivas para mitigar el ataque.

Objetivo del Script

El script `stp_root_claim.py` implementa un ataque de tipo **STP Root Bridge Hijack v3** que envía BPDUs de configuración STP maliciosos con los valores más bajos posibles para forzar a todos los switches de la red a reconocer al atacante como el nuevo Root Bridge:

- Anunciar una **Bridge Priority de 0** (menor que cualquier switch legítimo con prioridad 32768).
- Establecer un **Root Path Cost de 0**, indicando que el atacante es directamente el Root Bridge.
- Forzar una **reconvergencia STP** en toda la topología, causando inestabilidad en la red.
- Posicionar al atacante en el centro del árbol de spanning tree para interceptar tráfico.

Parámetros Utilizados

Parámetro	Valor	Descripción
Interfaz	eth0	Interfaz del atacante usada para enviar BPDUs
MAC atacante	00:0c:29:b0:f6:1c	MAC real de la interfaz del atacante
Bridge Priority	0	Prioridad mínima — inferior a cualquier switch legítimo (32768)
Bridge ID	0/00:0c:29:b0:f6:1c	Bridge ID construido con prioridad 0 + MAC del atacante
Root ID	0/00:0c:29:b0:f6:1c	El atacante se proclama Root Bridge
Root Path Cost	0	Costo de ruta al root — 0 indica ser el propio root
Intervalo BPDU	2s	BPDUs enviados cada 2 segundos (igual que Hello Time estándar)
Modo TCN	No	No se envían Topology Change Notifications adicionales
Destino STP	01:80:c2:00:00:00	Dirección multicast IEEE 802.1D estándar para BPDUs
BPDUs enviados	25	Total de BPDUs maliciosos enviados durante el ataque
Tiempo total	50.04s	Duración total del ataque

Requisitos para el Uso de la Herramienta

Sistema Operativo

- Kali Linux 2025.3 (o cualquier distribución Linux con soporte a raw sockets)

Privilegios

- Ejecución como root o con sudo (necesario para enviar tramas a nivel de capa 2)

Dependencias Python

```
# Requiere Scapy para construcción y envío de BPDUs STP
pip install scapy

# Módulos de la librería estándar utilizados:
import struct
```

```
import socket
import time
import threading
```

Hardware / Red

- Interfaz de red activa conectada directamente a un puerto de switch (modo access o trunk)
- Acceso al mismo dominio de broadcast que los switches objetivo
- STP debe estar habilitado en los switches (habilitado por defecto en Cisco IOS)

Entorno de Laboratorio

- GNS3 con 3 switches Cisco IOS IOSv Layer 2 (Swich-1, Swich-2, Swich-3)
- Kali Linux como nodo atacante conectado a Swich-3
- Solar-PuTTY para monitoreo simultáneo de los tres switches

Descripción del Funcionamiento del Script

El script opera en las siguientes fases:

Fase 1 — Identificación y Construcción del BPDU Malicioso

El script construye un frame Ethernet LLC con un BPDU de configuración STP (IEEE 802.1D) con los siguientes valores críticos:

- **Root ID Priority:** 0 (el más bajo posible)
- **Root ID MAC:** MAC del atacante 00:0c:29:b0:f6:1c
- **Bridge ID Priority:** 0
- **Root Path Cost:** 0 (el atacante se declara Root)
- **Destino:** 01:80:c2:00:00:00 (multicast STP estándar)

Fase 2 — Envío Continuo de BPDUs

El script envía BPDUs cada **2 segundos** (igual que el Hello Time de STP), manteniendo al atacante como Root Bridge activo. Los switches reciben estos BPDUs y, al comparar las prioridades, concluyen que el atacante tiene mejor candidatura como Root Bridge.

Fase 3 — Reconvergencia STP

Al recibir BPDUs con prioridad 0 (menor que sus propias prioridades de 32768+1), los switches:

1. Actualizan su tabla STP reconociendo al atacante como Root Bridge
2. Recalculan los caminos hacia el Root (Root Path)
3. Cambian los roles de puertos (Root Port, Designated Port)
4. La topología lógica de la red se reconfigura con el atacante en el centro

Fase 4 — Verificación del Éxito

En los switches se puede confirmar el ataque con:

```
Switch# show spanning-tree vlan 1
Root ID    Priority    0
           Address    000c.29b0.f61c   ← MAC del atacante como
Root
```

Fase 5 — Monitoreo con tcpdump

En paralelo, se capturan los BPDUs enviados para verificar el tráfico:

```
sudo tcpdump -i eth0 -e -nn ether dst 01:80:c2:00:00:00
```

Fase 6 — Finalización y Resumen

```
[v] Ataque finalizado.
    BPDUs enviados : 25
    Tiempo total   : 50.04s
```

Documentación de la Red

Tabla de Direcccionamiento

Nodo	Rol	Interfaz	IP / MAC	Notas
kali-linux-2025.3-vmware-amd64-1	Atacante	eth0 / e0	10.0.99.100	Envía BPDUs falsos como Root
Clonekali-1	Víctima	e0	10.0.99.50	Host en la red afectada
Swich-1	Switch L2	e0/e1/e2	Bridge: 0c1b.5678.0000	Root Bridge legítimo original
Swich-2	Switch L2	e0/e1/e2	Bridge: 0c84.bf01.0000	Switch no-root legítimo
Swich-3	Switch L2	e0/e1/e2	Bridge: 0ce4.db04.0000	Switch conectado al atacante
R1	Router	f0/0	N/A	Gateway de la red

Protocolo Explotado

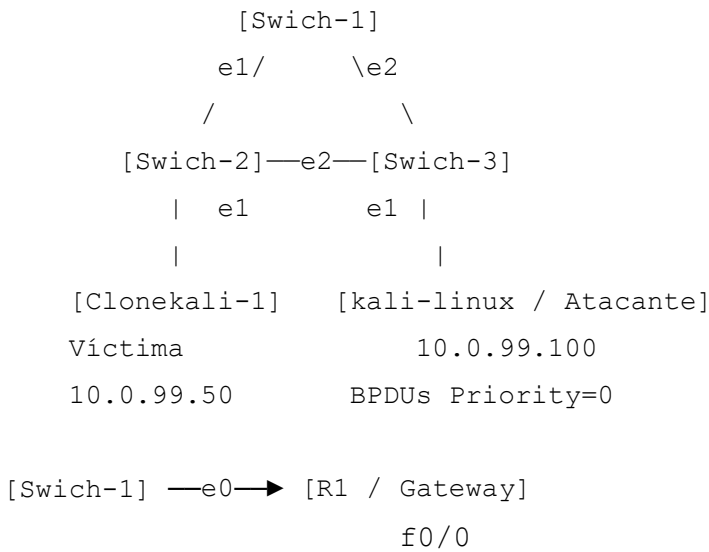
Protocolo	Capa	Descripción
STP	L2	Spanning Tree Protocol — sin autenticación de BPDUs, vulnerable a Root Hijack
BPDU	L2	Bridge Protocol Data Unit — cualquier dispositivo puede enviarlos sin restricción

Evidencia del Ataque — Cambio de Root Bridge

Momento	Root Bridge	Prioridad	Dirección MAC
Antes	Swich-2	32769	0c1b.5678.0000
Después	Atacante (Kali)	0	000c.29b0.f61c

Topología

La topología fue diseñada e implementada en **GNS3** con tres switches en triángulo y el atacante conectado a Swich-3:



La imagen de la topología se encuentra en la carpeta `/images/` del repositorio.

Capturas de Pantalla

Las capturas de pantalla se encuentran almacenadas en la carpeta `/images/` del repositorio.

#	Archivo	Descripción
1	imagen_01_topologia.png	Topología GNS3 con 3 switches, atacante y víctima — nombre y matrícula visibles
2	imagen_02_stp_swich2_antes.png	STP en Swich-2 antes del ataque — This bridge is the root, Priority 32769
3	imagen_03_stp_swich1_antes.png	STP en Swich-1 antes del ataque — This bridge is the root, Priority 32769

#	Archivo	Descripción
4	imagen_04_stp_swich3_configuracion.png	Configuración de interfaz en Switch-3: switchport mode access, spanning-tree portfast
5	imagen_05_ataque_iniciado.png	Script stp_root_claim.py en ejecución — Bridge Priority 0, BPDUs maliciosos enviados
6	imagen_06_tcpdump_bpds.png	Captura tcpdump de BPDUs STP con flag Topology change desde MAC del atacante
7	imagen_07_stp_swich3_root_hijacked.png	STP en Switch-3 después del ataque — Root ID Priority 0, MAC 000c.29b0.f61c (atacante)
8	imagen_08_ataque_finalizado.png	Resumen del ataque — 25 BPDUs enviados en 50.04s, instrucciones de verificación
9	imagen_09_contramedida_bpduguard.png	Contramedida aplicada: spanning-tree portfast + spanning-tree bpduguard enable

Medidas de Mitigación / Contramedidas

1. BPDU Guard (Contramedida Principal)

```
Switch(config)# interface g0/0
Switch(config-if)# switchport mode access
Switch(config-if)# spanning-tree portfast
Switch(config-if)# spanning-tree bpduguard enable
Switch(config-if)# end
Switch# write
```


BPDUs deshabilita inmediatamente (`err-disabled`) cualquier puerto que reciba un BPDUs STP. Combinado con PortFast, protege todos los puertos de acceso. **Es la contramedida más efectiva contra STP Root Hijack.**

2. Root Guard — Proteger el Root Bridge Legítimo

```
Switch(config)# interface g0/1
Switch(config-if)# spanning-tree guard root
```

Root Guard impide que un puerto se convierta en Root Port. Si se recibe un BPDUs superior en ese puerto, el puerto entra en estado `root-inconsistent` bloqueando el tráfico sin afectar otros puertos.

3. BPDUs Filter — Bloquear BPDUs Entrantes y Salientes

```
Switch(config-if)# spanning-tree bpdufilter enable
```

Descarta todos los BPDUs recibidos y no envía BPDUs en ese puerto. Usar con cautela — puede crear loops si se aplica en puertos de uplink.

4. Fijar la Prioridad del Root Bridge Legítimo

```
! En el switch que debe ser el Root Bridge permanente
Switch(config)# spanning-tree vlan 1 priority 0
! O usando el comando simplificado:
Switch(config)# spanning-tree vlan 1 root primary
```

Asignar la prioridad más baja al switch legítimo garantiza que siempre gane la elección de Root Bridge frente a cualquier atacante.

5. Recuperación Automática de Puertos err-disabled

```
Switch(config)# errdisable recovery cause bpduguard  
Switch(config)# errdisable recovery interval 300
```

6. Monitoreo y Detección

```
! Verificar Root Bridge actual  
Switch# show spanning-tree vlan 1  
! Verificar puertos en err-disabled  
Switch# show interfaces status err-disabled  
! Verificar estado de BPDU Guard  
Switch# show spanning-tree detail | include BPDU
```

Aviso Legal / Disclaimer

Este laboratorio fue realizado en un entorno **completamente controlado y simulado** con fines académicos y de investigación en seguridad informática. El uso de estas técnicas fuera de entornos autorizados es ilegal y contrario a la ética profesional. El autor no se hace responsable del uso indebido de este material.